

SecureForge Web

Relatório de Postura de Segurança

Gerado em 24/07/2026, 16:48:54

Identificação da aplicação

Ghost CMS

URL: https://demo.ghost.io/

Stack: JavaScript + TypeScript + HTML + CSS

Análise: Análise 24/07/2026 — Checklist Essential SecureForge v1.0

Concluída em: 24/07/2026

Gerado por: SecureForge Web (secureforgeweb@gmail.com)

Resumo executivo

42%

Score de postura

14

Total de achados

14

Achados abertos

0%

Taxa de resolução

Achados por severidade

Crítica: 3

Alta: 7

Média: 4

Plano de ação priorizado

AUTH-02 — Hash de senha forte

Crítica · Imediata · Aberto · Autenticação

Ação recomendada: Adote bcrypt (custo 12+) ou Argon2id para hash de senhas.

AUTHZ-03 — Rotas administrativas protegidas

Crítica · Imediata · Aberto · Autorização

Ação recomendada: Exija autenticação + autorização admin em todas as rotas /admin.

INPUT-02 — Queries SQL parametrizadas

Crítica · Imediata · Aberto · Validação de entrada

Ação recomendada: Use ORM ou prepared statements; nunca concatene SQL com input do usuário.

AUTH-01 — Política de senha mínima

Alta · Curto prazo · Aberto · Autenticação

Ação recomendada: Exigir 8+ caracteres com maiúscula, minúscula, número e especial.

AUTHZ-01 — Controle de acesso por perfil

Alta · Curto prazo · Aberto · Autorização

Ação recomendada: Mapeie papéis e aplique verificação em todas as rotas sensíveis.

AUTHZ-02 — Princípio do menor privilégio

Alta · Curto prazo · Aberto · Autorização

Ação recomendada: Audite papéis e remova acessos desnecessários.

INPUT-03 — Sanitização anti-XSS

Alta · Curto prazo · Aberto · Validação de entrada

Ação recomendada: Escape output, use CSP e frameworks que sanitizam por padrão.

HEADER-01 — Content-Security-Policy

Alta · Curto prazo · Aberto · Headers de segurança

Ação recomendada: Defina Content-Security-Policy adequada ao tipo de aplicação.

HEADER-02 — Strict-Transport-Security

Alta · Curto prazo · Aberto · Headers de segurança

Ação recomendada: Configure Strict-Transport-Security em produção.

EXPOS-01 — APIs sensíveis autenticadas

Alta · Curto prazo · Aberto · Exposição de endpoints

Ação recomendada: Revise rotas e exija token/sessão em endpoints sensíveis.

AUTH-04 — Expiração de sessão

Média · Médio prazo · Aberto · Autenticação

Ação recomendada: Defina timeout de sessão e renovação segura de tokens.

HEADER-03 — X-Frame-Options / frame-ancestors

Média · Médio prazo · Aberto · Headers de segurança

Ação recomendada: Use X-Frame-Options: DENY ou CSP frame-ancestors.

HEADER-04 — X-Content-Type-Options

Média · Médio prazo · Aberto · Headers de segurança

Ação recomendada: Defina X-Content-Type-Options: nosniff.

SURF-02 — Dependências atualizadas

Média · Médio prazo · Aberto · Superfície de ataque

Ação recomendada: Execute auditoria (npm audit) e atualize pacotes com CVEs críticos.

